SECURITY INCIDENT REPORT — CONFIDENTIAL

Transmitted via Secure Internal Email — Do Not Forward

From:	admin.user@MaxineJonesProject.onmicrosoft.com
To:	securityteam@MaxineJonesProject.onmicrosoft.com; mike.thompson@MaxineJonesProject.onmicrosoft.com
CC:	sarah.johnson@MaxineJonesProject.onmicrosoft.com
Date:	March 22, 2026 — 7:15 AM CST
Subject:	[HIGH PRIORITY] Security Incident Report — Phishing-Based Credential Compromise — John Smith (HR Department)
Classification:	CONFIDENTIAL — Internal Use Only

Team,

I am writing to formally document and report a confirmed security incident involving the compromise of a standard user account belonging to John Smith, HR Department. This incident began with a vishing (voice phishing) attack at approximately 2:30 AM CST on March 22, 2026, and resulted in unauthorized access to corporate resources. Full details, evidence, and remediation actions are documented below.

---

1. Incident Overview

Incident ID	INC-2026-0322-001
Date Reported	March 22, 2026
Time of Initial Attack	2:30 AM CST (Vishing call received)
Time Detected	6:10 AM CST (Sign-in log anomaly identified)
Reported By	Admin User — IT Security Administrator
Affected User	John Smith — HR Department (john.smith@MaxineJonesProject.onmicrosoft.com)
Severity	HIGH
Status	CONTAINED — Remediation Complete
Attack Type	Vishing (Voice Phishing) + Credential Compromise + Unauthorized Account Access

---

2. Attack Narrative

2.1 Initial Compromise — Vishing Attack (2:30 AM CST)

At approximately 2:30 AM CST on March 22, 2026, John Smith received an unsolicited phone call from the number +1 (312) 555-0194. The caller identified themselves as a Microsoft Azure Support Technician named "David Harrison" and claimed to be calling on behalf of the IT Security team. The caller informed John that his account had been flagged for suspicious activity and that his password needed to be reset immediately to prevent account lockout.

The caller used urgency and authority to pressure John into complying, stating: "This needs to be resolved tonight or your account will be suspended and you will lose access to all company systems by morning." The caller then directed John to navigate to the company's Microsoft 365 login page and enter his credentials to "verify his identity" before the reset could proceed.

John, believing the call to be legitimate, complied and provided his current account credentials. The attacker now had full access to John's username and password.

2.2 Unauthorized Access (6:10 AM CST)

Using the stolen credentials, the attacker successfully authenticated to the corporate Microsoft 365 environment at 6:10 AM CST. The sign-in was completed using only single-factor authentication — no MFA challenge was presented due to a control gap identified during this investigation (see Section 4).

Once authenticated, the attacker performed the following malicious actions:

- Accessed the Microsoft 365 OfficeHome portal
- Browsed John Smith's accessible applications and group memberships
- Performed self-service group management queries to enumerate organizational structure
- Created a new security group named "THIS IS PHISHED" (Group ID: e69881d1-056e-42bd-8713-616d9b1956ac) — likely a marker to confirm access and test permissions
- Attempted to escalate privileges by adding themselves as owner of the newly created group
- Changed the account password at 6:41 AM CST via self-service password reset

The attacker's activity was logged across multiple IP addresses, indicating use of cloud infrastructure or proxy services to obfuscate their true location:

- 172.183.155.156 (Microsoft Azure datacenter — suspicious)
- 20.228.63.16 (Microsoft Azure — suspicious)
- 135.232.161.20 (Microsoft Azure — suspicious)

---

3. Evidence & Log Analysis

3.1 Microsoft Entra ID Sign-In Logs

The following sign-in events were captured from the Entra ID interactive sign-in logs for user john.smith@MaxineJonesProject.onmicrosoft.com:

Timestamp (UTC)	Application	Status	Auth Method	Error Code
2026-03-22 06:10:29	OfficeHome	FAILURE	Single-factor	50126 — Bad password
2026-03-22 06:10:40	OfficeHome	Interrupted	Single-factor	50140 — KMSI prompt

2026-03-22 06:10:44	OfficeHome	SUCCESS	Single-factor ONLY	None
2026-03-22 06:41:02	Password Reset Service	SUCCESS	Self-service	None

Note: All sign-ins originated from Chicago, Illinois, US — consistent with attacker using VPN or cloud proxy to appear local.

3.2 Entra ID Audit Logs — Malicious Activity

The following audit log entries confirm unauthorized activity performed by the attacker after gaining access:

Timestamp (UTC)	Activity	Result	Details
06:41:02	Change password (self-service)	SUCCESS	Password changed by attacker
06:41:58	Add group	SUCCESS	Group: THIS IS PHISHED
06:41:58	Add owner to group	SUCCESS	Attacker added as owner
06:41:58	Add member to group	SUCCESS	John Smith added to malicious group
06:42–06:44	Group Management queries	SUCCESS	Org structure enumeration

3.3 Wazuh Endpoint Telemetry

Wazuh SIEM (agent: Windows-Endpoint, IP: 10.0.0.76) captured the following endpoint activity during the incident window. The Wazuh agent confirmed an active connection to the cloud manager at 3.131.143.101:1514 throughout the incident, providing continuous monitoring.

- 350+ security alerts generated during the investigation period
- CIS Microsoft Windows 11 Enterprise Benchmark v3.0.0 scan: 349 failed checks identified (pre-existing hardening gaps)
- Security event ID 4624 — Successful logon events detected
- Security event ID 4672 — Special privilege assignments logged
- Credential Manager read events (5379) — potential credential access activity
- Active HTTPS connections to multiple Microsoft Azure endpoints observed

---

4. Security Findings & Control Gaps

Finding 1: MFA Not Enforced — Critical Control Gap

Despite Conditional Access policies being configured to require MFA, the attacker successfully authenticated using only a username and password. Investigation revealed that John Smith had not completed MFA registration, which prevented enforcement.

Impact: Full account takeover possible with credentials alone. MFA policy alone is insufficient without user registration enforcement.

Finding 2: Insufficient Vishing Awareness Training

The affected user was successfully manipulated by a caller impersonating IT support. The use of urgency, authority, and after-hours timing are classic social engineering tactics that existing security training did not adequately address.

Finding 3: Self-Service Password Reset Exploited

The attacker leveraged the self-service password reset capability to lock out the legitimate user and take permanent control of the account. This feature was not restricted by location or device compliance requirements.

Finding 4: Endpoint Security Gaps

The Wazuh SCA scan identified 349 failed CIS benchmark checks on the Windows 11 endpoint (score: 26/100). These represent significant hardening gaps that increase risk of lateral movement in the event of a more advanced attack.

---

5. Incident Response Actions Taken

Immediate Containment

- Revoked all active sessions for john.smith@MaxineJonesProject.onmicrosoft.com
- Reset John Smith's password using admin-initiated reset (temporary password issued)
- Deleted malicious group "THIS IS PHISHED" from Entra ID
- Blocked the attacker's known IP addresses via Conditional Access Named Locations

Remediation & Hardening

- Enforced MFA registration for all users via Conditional Access baseline policy
- Implemented CA-ZT-01: Block Legacy Authentication — prevents MFA bypass via legacy protocols
- Implemented CA-ZT-02: Block Non-Trusted Locations — restricts access to known geographic locations
- Implemented CA-ZT-03: Require Compliant Device — enforces device health checks before access
- Implemented CA-ZT-04: Risk-Based Sign-In Policy — blocks high-risk authentication attempts
- Implemented CA-ZT-05: Salesforce MFA Policy — requires MFA specifically for Salesforce CRM access
- Updated Windows 11 endpoint password policy: minimum 12 characters, 90-day expiration
- Configured account lockout: 5 failed attempts triggers 30-minute lockout

Post-Incident Validation

- Confirmed MFA enforcement active for all Salesforce-Users group members

- Verified Wazuh agent reporting active (Windows-Endpoint — Status: Active)
- Reviewed and validated all Conditional Access policies are in ON state (not report-only)
- Confirmed no additional unauthorized group memberships or role assignments

---

6. MITRE ATT&CK Framework Mapping

Tactic	Technique ID	Description
Initial Access	T1566.004	Phishing — Vishing (Voice Phishing)
Credential Access	T1078	Valid Accounts — use of legitimate stolen credentials
Persistence	T1098	Account Manipulation — password change, group creation
Discovery	T1069	Permission Groups Discovery — org structure enumeration
Defense Evasion	T1078.004	Cloud Accounts — exploiting cloud identity provider

---

7. Recommendations

Immediate (Within 24 Hours)

- Mandate MFA registration for ALL users before next login — enforce via Conditional Access registration policy
- Conduct emergency vishing awareness training for all staff, with emphasis on after-hours calls
- Review and restrict self-service password reset to require manager approval or MFA verification

Short-Term (Within 30 Days)

- Remediate top 50 CIS benchmark failures identified on Windows endpoints
- Implement privileged identity management (PIM) to require approval for sensitive role activations
- Deploy Microsoft Defender for Identity to detect lateral movement and credential attacks
- Configure Salesforce login history monitoring and anomaly alerting

Long-Term (Within 90 Days)

- Enroll all endpoints in Microsoft Intune for device compliance enforcement
- Implement FIDO2 phishing-resistant MFA (hardware keys) for privileged accounts
- Conduct full PCI DSS compliance review of identity and access management controls
- Establish monthly security awareness training program with phishing simulations

---

7. Severity Justification

This incident was classified as HIGH severity based on the following factors:

- Identity compromise in a cloud environment (Microsoft Entra ID) — credential-based attacks are the leading vector for enterprise breaches
- Potential exposure of employee PII — John Smith is an HR employee with access to employee records, compensation data, and organizational structure
- Privilege escalation attempt — the attacker created a security group and attempted to add themselves as owner, indicating intent to expand access
- Self-service password reset exploited — the attacker locked out the legitimate user, demonstrating intent to maintain persistence
- Salesforce CRM accessible via SSO — a successful Salesforce login would have exposed customer and employee data
- No MFA enforcement — the absence of MFA enforcement meant credentials alone were sufficient for full account takeover
- Regulatory impact — HR data is classified as PII under applicable privacy regulations; unauthorized access triggers potential breach notification obligations

---

8. Business Impact Assessment

Impact Area	Potential Exposure	Risk Level
Employee PII	Names, emails, roles, compensation data accessible via HR account	HIGH
Organizational Structure	Full org chart, group memberships, reporting lines exposed via group enumeration	HIGH
Salesforce CRM	Customer and employee records potentially accessible via SSO if Salesforce login succeeded	HIGH
Regulatory / Compliance	PII exposure may trigger breach notification requirements under applicable privacy laws	MEDIUM
Reputational	Internal trust impact if employee data was accessed; external impact if customer data reached	MEDIUM
Operational	Account lockout caused temporary productivity loss for affected HR employee	LOW

---

9. Detection Gap Analysis

Why Conditional Access Did Not Trigger MFA

Conditional Access policies were configured correctly but failed to enforce MFA for the following reasons:

- John Smith had not completed MFA registration — Microsoft Entra ID cannot challenge a user for MFA if no authentication method is registered, even if a policy requires it
- The policy was set to 'On' but without a registration enforcement policy, users who never registered bypass the MFA requirement on initial authentication
- Remediation: A new Conditional Access registration policy was implemented requiring all users to register MFA before accessing any resources

Why Risk-Based Policies Did Not Fire

The risk-based Conditional Access policies (sign-in risk and user risk) did not activate because:

- The attacker used a Chicago, Illinois IP address consistent with the user's normal location — Entra ID risk engine did not flag the location as anomalous
- The attacker used a standard browser (Chrome 146.0 on Windows 10) matching the user's normal device profile
- Azure AD Identity Protection requires P2 licensing and historical baseline data to establish risk scores — the tenant lacked sufficient historical sign-in data to establish a behavioral baseline
- Remediation: Entra ID P2 license activated and risk policies updated; continued monitoring will build the behavioral baseline over time

Why Alerts Were Not Generated Earlier

- Wazuh endpoint monitoring did not have direct visibility into cloud identity events — no Microsoft Graph API integration was configured at time of incident
- The attacker's activity occurred primarily in the cloud layer (Entra ID, Microsoft 365) rather than on the monitored endpoint
- No automated alerting was configured for after-hours login attempts or self-service group creation events
- Remediation: Entra ID sign-in alert rules configured; Wazuh Microsoft Graph integration planned for deployment

---

10. Incident Metrics & KPIs

Metric	Value
Time of Initial Attack (Vishing call)	2:30 AM CST — March 22, 2026
Time of First Unauthorized Login	6:10 AM CST — March 22, 2026
Time to Detect	~3 hours 40 minutes (sign-in log review)
Time to Contain (Session Revocation)	<15 minutes after detection
Time to Remediate (Password Reset)	<30 minutes after detection
Total Incident Duration	~4 hours 15 minutes (attack to full containment)
Number of Wazuh Alerts Correlated	350+ endpoint security alerts reviewed
Sign-In Events Analyzed	7 John Smith sign-in events reviewed
Audit Log Entries Analyzed	15+ audit log entries correlated

Malicious Objects Created	1 security group (THIS IS PHISHED)
Accounts Compromised	1 (john.smith@MaxineJonesProject.onmicrosoft.com)
Zero Trust Policies Implemented Post-Incident	5 new Conditional Access policies deployed

---

11. Indicators of Compromise (IOCs)

Network IOCs — Attacker IP Addresses

IP Address	Provider	Activity
172.183.155.156	Microsoft Azure Datacenter	Group management queries
20.228.63.16	Microsoft Azure Datacenter	Approval and group enumeration
135.232.161.20	Microsoft Azure Datacenter	Malicious group creation and ownership
172.183.155.144-153	Microsoft Azure IP Range	Multiple group management queries

Identity IOCs

- Compromised account: john.smith@MaxineJonesProject.onmicrosoft.com
- Compromised account Object ID: e011488a-a537-4175-abec-8fefae93f430
- Malicious group created: THIS IS PHISHED
- Malicious group ID: e69881d1-056e-42bd-8713-616d9b1956ac
- Attacker phone number: +1 (312) 555-0194 (spoofed)
- Attacker alias used: David Harrison (Microsoft Azure Support Technician)

Behavioral IOCs

- After-hours authentication attempt (2:30 AM CST)
- Single-factor authentication success despite MFA policy
- Self-service password reset immediately following initial login
- Group creation with suspicious display name
- Multiple rapid group management API calls within 3-minute window
- Authentication from Microsoft Azure datacenter IPs (not typical user device)

Timeline Markers

Timestamp (CST)	Event
2:30 AM	Vishing call received by John Smith from +1 (312) 555-0194
~2:35 AM	John Smith surrenders credentials to attacker
6:10:29 AM	First failed login attempt — error 50126 (bad password)

6:10:44 AM	Successful single-factor login to OfficeHome
6:41:02 AM	Self-service password change — legitimate user locked out
6:41:58 AM	Malicious group THIS IS PHISHED created
6:41:58 AM	Attacker added as group owner — privilege escalation attempt
6:42–6:44 AM	Organizational structure enumeration via group management API
~7:00 AM	Incident detected via sign-in log review
~7:10 AM	Sessions revoked, password reset initiated
~7:15 AM	Incident report drafted and distributed to security team
~7:30 AM	Zero Trust Conditional Access policies deployed

---

12. Lessons Learned

- MFA policy configuration alone is insufficient — user registration must be enforced as a prerequisite to system access. A registration policy is now mandatory during onboarding.
- Risk-based Conditional Access requires historical behavioral baselines to function effectively — tenants should be monitored for at least 30 days before relying on adaptive risk controls.
- After-hours vishing attacks exploit reduced user vigilance — security awareness training must specifically address social engineering scenarios involving IT impersonation and urgency tactics.
- Self-service password reset requires additional verification controls — manager approval or secondary verification should be required for all self-service resets.
- Cloud identity events must be monitored in the SIEM — endpoint monitoring alone is insufficient; identity telemetry from Entra ID must be integrated into Wazuh or equivalent SIEM.
- The attacker's creation of the group named 'THIS IS PHISHED' suggests either testing access boundaries or deliberate taunting — both indicate a relatively unsophisticated attacker who was not attempting stealth.

---

13. Closing Statement

This incident demonstrates the critical importance of layered identity security controls. A single control failure — incomplete MFA registration — was sufficient to allow an attacker with stolen credentials to gain unauthorized access to corporate systems. The Zero Trust policies implemented following this incident significantly reduce the attack surface for future credential-based attacks.

All evidence including sign-in logs, audit logs, and endpoint telemetry have been preserved and are available upon request for further investigation or compliance review.

Please do not hesitate to reach out with any questions or concerns.

Regards,
Admin User

IT Security Administrator
admin.user@MaxineJonesProject.onmicrosoft.com
Maxine Jones Project — Information Security Team

CONFIDENTIAL — This document contains sensitive security information. Unauthorized distribution is prohibited.